

QuarkShield.ai

End-to-End Test Report & Security Remediation

System under test	https://quarkshield.ai (production 13.140.40.99) + tenant subdomains
Repository	github.com/spinovation/quarkshield-ai — branch fix/auth-and-schema
Components	React 19 + Vite UI, Express + TypeScript + PostgreSQL API, Go host agent
Report date	September 26, 2026
Prepared by	Automated review + remediation (Claude Code)
Status	PR #1 open (23 commits), all verified locally; NOT yet deployed

Confidential. This report documents functional and security testing of QuarkShield.ai and the remediation applied. It records the state observed on 2026-09-25/26. Re-verify against live state before relying on any single line.

1. Executive summary

The product's core detection engine is sound: the host scanner runs on macOS and Linux, correctly identifies planted RSA, ECDSA and Ed25519 keys, and never uploads private-key material. However, the initial review found that the backend enforced **no authentication or authorization of any kind**, the database **would not build on a fresh install**, and several advertised features were simulated or cosmetic.

All blocker and critical issues have since been fixed on branch **fix/auth-and-schema** (9 commits, open as PR #1) and verified locally against a fresh PostgreSQL. The Unified Integrations Hub and Hybrid Quantum TLS Proxy Gateway were tested end-to-end and are functional behind the new authentication and tenant-isolation layer; their discovery/handshake data remains a simulated backend (documented).

Area	Result	Notes
Authentication & session	Fixed	No API auth → JWT httpOnly cookie, bcrypt, RBAC, 2FA
Two-factor auth (TOTP)	Fixed	Cosmetic → real enrollment, enforcement, recovery codes
Database bootstrap	Fixed	Fresh DB now builds all 19 tables
SSRF (probe + git)	Fixed	Internal/loopback/metadata targets blocked
Licensing	Fixed	Backdoor + hardcoded secret removed; seats/expiry enforced
Tenant isolation	Fixed	Cross-tenant access returns 403
Local agent GUI	Fixed	Origin/Host/CSRF guard; backdoor removed
Integrations Hub (all 4)	Fixed	AWS KMS, Vault, Azure KV, AD CS — all real backends
PQC Proxy Gateway	Fixed	Config-generate + real upstream validate

DEF-51 is complete: all four connectors (AWS KMS, HashiCorp Vault, Azure Key Vault, AD CS) are real backends, and the proxy is config-generate + real validate.

2. Scope, environment & legend

Roles exercised: anonymous visitor, Super Admin, Partner/Corporate (tenant) Admin, tenant user. Machines: macOS (Apple Silicon), Linux (Docker amd64 + arm64). Live public checks were read-only or local; authentication-bypass and destructive cases were verified on a local copy, never against production.

Pass	Ran and matched the expected result.
Fail	Ran and did not match (defect logged).
Fixed	Defect remediated on the branch and re-verified.
Code-verified	Confirmed by reading source; needs a live run to confirm.
Blocked / Not run	Needs a staging environment, Windows VM, or approval.

3. Feature test results

3.1 Landing page & public features

Public site loads with no console errors; all internal links and downloads resolve.

ID	Test	Result
LP-01	Landing page loads, correct title, no console errors	Pass
LP-04	TLS probe against PQC hosts (cloudflare/google/github)	Pass
LP-07	TLS probe blocks internal addresses (SSRF)	Fixed
LP-10	Mosca planner sector presets update verdict	Pass
LP-13	macOS scanner downloads match release builds	Pass
LP-21	Security headers (HSTS/X-Frame/X-Content-Type)	Fixed

3.2 Authentication, password & session

Backend now issues a signed JWT in an httpOnly cookie scoped to .quarkshield.ai; passwords use bcrypt with legacy-hash auto-upgrade.

ID	Test	Result
AU-01	Valid login issues a session	Fixed
AU-02	Wrong password rejected (401)	Fixed
AU-03	Passwordless / workspace-name login rejected	Fixed
AU-05	Signed session cookie set (not localStorage)	Fixed
AU-06	Auth endpoints rate limited	Fixed
AU-08	Locked/disabled user blocked at login	Fixed
AU-11	Forgot-password uses single-use reset token	Fixed
AU-11b	/reset-password page consumes the emailed link	Fixed
AU-12	No account enumeration on forgot-password	Fixed
AU-13	401 on a protected call redirects to sign-in (no demo-data masking)	Fixed
AU-14	Passwords hashed with bcrypt (was SHA-256)	Fixed

3.3 Two-factor authentication (TOTP)

Real TOTP replaces the previous UI-only 2FA. Verified end-to-end with a generated authenticator code.

ID	Test	Result
2FA-01	Enroll: QR / otpauth secret generated	Fixed
2FA-02	Verify enables 2FA, returns 8 recovery codes	Fixed
2FA-03	Login without code returns twoFactorRequired	Fixed
2FA-04	Login with wrong code rejected (401)	Fixed
2FA-05	Login with valid TOTP succeeds	Fixed
2FA-06	Recovery code works once, rejected on reuse	Fixed
2FA-07	Secrets encrypted at rest (AES-256-GCM)	Fixed
2FA-08	Tenant policy (mandatory/admins-only) forces enrollment at login	Fixed

3.4 Tenants, partners & licensing

Endpoints are now super-admin-gated; ingest enforces license expiry and seat limits.

ID	Test	Result
TN-01	Create tenant (super admin only)	Fixed
LI-02	Seat limit enforced at agent ingest	Fixed

ID	Test	Result
LI-03	Expired license rejected at ingest	Fixed
LI-06	License forgery blocked (secret in env, no backdoor)	Fixed
TN-06	Deleted tenant/edits survive server restart	Fixed
LI-09	Stripe checkout	Not run

3.5 Users, RBAC & tenant isolation

Verified live on a local copy with two tenant users in different tenants.

ID	Test	Result
RB-02	Anonymous cannot reach admin API (401)	Fixed
RB-01	Tenant user cannot reach admin API (403)	Fixed
IS-01	Cross-tenant portal-data blocked (403)	Fixed
IS-02	Fleet tokens scoped to caller's tenant	Fixed
IS-04	Client-supplied tenant header/param ignored	Fixed
IS-06	Unauthenticated account-takeover chain closed	Fixed

3.6 Scanning (macOS / Linux / Windows)

Scanner run against planted keys on macOS and Linux (amd64 + arm64) in containers.

ID	Test	Result
SC-01	macOS scan finds planted keys	Pass
SC-02	Linux amd64/arm64 scan finds planted keys	Pass
SC-05	No private-key material in the uploaded payload	Pass
SC-08	Key-size detection accuracy (heuristic)	Fail
SC-18	Cloned-VM machines no longer merge (dedup rule removed)	Fixed
SC-04	Windows scan on a VM	Blocked

3.7 Exports, Git scanner & CI gate

CBOM/CSV exports function; CycloneDX schema-conformance remains a follow-up.

ID	Test	Result
GT-01	Remote git repo scan returns findings	Pass
GT-02	Git scanner blocks internal hosts (SSRF)	Fixed
GT-03	Git credential sent only to exact host	Fixed
EX-01	CBOM JSON export downloads	Pass
EX-02	CBOM validates against CycloneDX 1.6 schema	Fail
EX-06	PDF/DOCX report export	Fail

4. Unified Integrations Hub & PQC Proxy Gateway (requested)

Every endpoint requires an authenticated session and is scoped to the caller's tenant. DEF-51 Phase 1 has since made AWS KMS a real, keyless connector, made the proxy a config-generate + validate feature with a real upstream probe, and made the not-yet-implemented providers report an honest PREVIEW status instead of a fake healthy result.

4.1 Unified Integrations Hub (PKI & Cloud KMS connectors)

All four connectors are now real backends. No provider fakes a healthy status or returns mock inventory.

ID	Test	Result
IH-01	AWS KMS: keyless (cross-account role) discovery	Fixed
IH-02	AWS KMS: verified vs LocalStack (RSA/ECDSA/AES classified)	Fixed
IH-03	HashiCorp Vault: token/AppRole, Transit + PKI discovery	Fixed
IH-04	HashiCorp Vault: verified vs real Vault dev container	Fixed
IH-05	Azure Key Vault: real SDK, keyless-first + service principal	Fixed
IH-06	AD CS: agent-reported inventory (push, certutil)	Fixed
IH-07	Stored secrets encrypted at rest (AES-256-GCM)	Fixed
IH-08	Bad credentials -> connector saved + errored (no fake success)	Fixed
IH-09	Requires authentication (401 without session); tenant-scoped	Fixed

Credential model is keyless-first: AWS uses STS AssumeRole (cross-account, read-only) and Azure uses managed identity by default; where a secret is unavoidable (Vault token/AppRole, Azure service-principal secret) it is stored AES-256-GCM encrypted, never in plaintext. Verified: AWS KMS vs LocalStack (4 keys), HashiCorp Vault vs a real dev container (4 transit keys, token sealed), Azure wired through the real SDK with honest failure on bad creds + mapping unit-tested, and AD CS via the agent push endpoint end-to-end. Azure live-with-keys needs a real tenant; AD CS live needs a domain-joined Windows CA.

4.2 Hybrid Quantum TLS Proxy Gateway

Reframed as config-generate + validate (QuarkShield emits nginx/Envoy config the customer deploys; it does not run the proxy).

ID	Test	Result
PX-01	Create gateway (custom port/upstream honored)	Pass
PX-02	List gateways (tenant-scoped)	Pass
PX-03	Validate internal upstream = config-valid (SSRF-safe, no connect)	Fixed
PX-04	Validate public upstream = real TLS probe (TLSv1.3 + cipher)	Fixed
PX-05	Config template (nginx/Envoy) generated	Pass
PX-06	Requires authentication (401 without session)	Fixed
PX-07	Cross-tenant gateway access blocked (403)	Fixed
PX-08	Delete gateway	Pass

The fake fixed-handshake result was replaced: internal/loopback upstreams (the usual terminating-proxy case) are format-validated only so the server never connects to internal hosts on a caller's behalf; public upstreams get a real TLS/TCP probe reporting the actual negotiated protocol and cipher. Running live per-tenant proxies remains out of scope by design.

5. Remediation delivered (PR #1, branch fix/auth-and-schema)

Nine commits, each built and verified locally against a fresh PostgreSQL. No UI files were changed, so the Super Admin console header, the searchable Algomeld tenant dropdown, and multi-tenant subdomain isolation are preserved (isolation is now also enforced server-side).

#	Commit	Defects
1	fix(db): build schema reliably on a fresh database	DEF-33
2	feat(auth): real authentication & authorization on the API	DEF-01/02/11
3	fix(security): SSRF guards on TLS probe and git scanner	DEF-03/49
4	fix(license): remove backdoor + secret; enforce expiry & seats	DEF-20/21/22/35
5	fix(security): security headers, auth rate limiting, random onboarding pw	DEF-04/09
6	fix(db): stop destructive per-boot migrations and seed overwrites	DEF-18/35
7	feat(2fa): real TOTP two-factor authentication	DEF-12
8	fix(auth): secure forgot-password with single-use reset token	DEF-08
9	fix(agent): lock down local GUI server and remove license backdoor	DEF-20/41
10	fix(db): schema splitter ignores -- comments; restore seed loading	DEF-33
11	feat(2fa): enforce tenant 2FA policy at login	DEF-12b
12	feat(ui): password-reset page and global 401 handling	DEF-55
13	merge: bring main (UI Wiz/Splunk removal) into the branch	—
14	feat(integrations): real AWS KMS discovery; proxy validate; preview labels	DEF-51
15	feat(integrations): real Azure Key Vault + HashiCorp Vault discovery	DEF-51
16	feat(integrations): AD CS discovery via the host agent	DEF-51
17	fix: valid CycloneDX 1.6, honest attestation, CSV + template safety	DEF-44/45/46/52
18	fix: real key sizes, 404s, offline staleness, current AI model	SC-08/DEF-14/37/53
19	feat(support): persist Help/Feedback attachments; surface real errors	DEF-48
20	fix(ci-gate): make the CI/CD gate actually block (fail closed)	DEF-50
21	feat(fleet): cryptographic drift detection + on-demand pull	DEF-36/38
22	feat(alerts): email + webhook compliance alerts on ingest	DEF-54
23	feat(reports): server-side executive PDF & DOCX audit reports	DEF-47

5.1 Deploy prerequisites

Set before deploying the branch: **JWT_SECRET** (32+ random chars), **COOKIE_DOMAIN=quarkshield.ai**, **ALLOWED_ORIGINS**, **NODE_ENV=production**, **LICENSE_SIGNING_SECRET**, **TWO_FACTOR_ENC_KEY**, **CONNECTOR_ENC_KEY** (encrypts stored connector secrets), and **BOOTSTRAP_ADMIN_EMAIL** / **BOOTSTRAP_ADMIN_PASSWORD** (12+ chars) for a known break-glass login. Deploy backend and frontend together; roll back with `git revert` if needed.

6. What still needs to be fixed

The blocker and critical security defects are fixed on the branch. The items below remain open, grouped by priority. Each names the fix. None are yet started unless noted.

Nearly every defect from the review is now fixed on the branch (23 commits). Only minor UI/ops items and an agent release step remain. The medium and low-priority batches — DEF-44/45/46/52 (CycloneDX + injection safety), SC-08 (real key sizes), DEF-14/37/53, DEF-48 (support attachments), DEF-50 (CI gate), DEF-36/38 (drift + on-demand pull), DEF-54 (email + webhook alerts) and DEF-47 (PDF/DOCX reports) — are all done and verified.

6.1 Remaining

Ref	Issue	Recommended fix
Agent release	The agent-side fixes (SC-08 key sizes, AD CS, --poll, CycloneDX) are committed but not yet shipped	Rebuild + re-sign the Go agent (inject LicenseSigningSecret via -ldflags to match the server) and publish new binaries
UI wiring	New endpoints (executive report PDF/DOCX, drift history) have no button yet	Add UI controls that call GET /api/reports/executive and GET /api/fleet/drift
DEF-27	Temp passwords are still returned in some admin API responses (now behind auth, so low severity)	Deliver via email only; drop the password field from responses
DEF-39/40	macOS build not notarized; Windows Authenticode chain unverified on a clean box	Add notarytool + stapler; verify the full Windows chain
DEF-10	macOS .dmg is older than the shipped binaries	Rebuild the .dmg with each release
DEF-07 / DEF-13 / DEF-56	Probe error surfacing (needs UI coordination); phone header overflow; unconfirmed AdminPanel button refs	UI polish pass; DEF-56 could not be reproduced (UI builds clean)

Deferred by design (build only when a customer needs it): CUI/FCI classification for Gmail; Google Workspace connectors; inherited-controls mapping. Full per-item context lives in the live test-plan document.

7. Verification evidence

Consolidated local run (fresh PostgreSQL + freshly built server and Go agent): 19/19 core checks passed — schema builds (19 tables); unauthenticated admin access 401; passwordless logins 401; break-glass cookie login reaches admin; tenant user limited to its own tenant (cross-tenant / admin 403); legacy hash logs in and upgrades to bcrypt; SSRF targets 400; HSTS present; 2FA enroll → blocked without code → valid code OK → recovery code single-use; forgot-password neutral + token created + bad token 400. Integrations Hub (8 checks) and Proxy Gateway (8 checks) exercised end-to-end and passing. The Go agent's license test passes.

DEF-12b (tenant 2FA policy), 6/6: a mandatory-policy tenant returns mustEnroll2FA with a restricted session that is blocked from tenant data (403) but can reach 2FA setup; after enrollment full access is granted and later logins require the TOTP code; an admins-only policy leaves non-admins unaffected. DEF-55 (frontend), verified in a real browser against the built UI: the /reset-password page renders and submits, the new password then logs in while the old one is rejected and the token is single-use, and a 401 on a protected call redirects to sign-in (?session=expired). After merging main, the branch rebuilds clean: server tsc, UI vite build, and Go agent build all pass.

DEF-51 (all connectors). AWS KMS vs LocalStack: real ListKeys ping + sync discovered the 4 seeded keys with correct RSA-2048/4096 + ECDSA (vulnerable) and AES-256 (secure) classification; bad creds -> connector saved + errored, not 500. HashiCorp Vault vs a real dev container: 4 transit keys discovered (RSA/ECDSA/Ed25519 vulnerable, AES secure) and the token stored sealed (no plaintext). Azure Key Vault: wired through the real SDK end-to-end (honest UNREACHABLE on bad creds, secret sealed) with key-type mapping unit-tested 5/5. AD CS: agent report endpoint end-to-end (token-auth, 401 without a token, connector auto-created, assets persisted, AGENT-REPORTED status, idempotent re-report); the Go agent builds for host and windows/amd64 and its certutil parser is unit-tested. Proxy validate: internal upstream -> config-valid (no server-side connection); public https upstream -> real TLSv1.3 probe with the actual cipher.

Medium/low + follow-up batches. CycloneDX helper unit-tested 10/10 (bom-ref, valid enum, nistQuantumSecurityLevel, honest HMAC) and the agent CBOM confirmed spec-shaped; SC-08 verified real sizes on planted RSA-2048/3072/4096, EC and Ed25519 keys; unknown /api and /downloads return 404 while real downloads + SPA routes still serve; a stale machine shows offline. DEF-48: a ticket with a base64 attachment stores the bytes, with 400s for empty message / bad email / too many files. DEF-50: empty input -> ERROR/exit1, a leaked-RSA-key repo -> BLOCKED/exit1 via the real runner, a clean repo -> PASSED/exit0. DEF-36: two ingests record exactly one added + one removed drift event. DEF-38: a queued command is fetched once then consumed (401 without a token). DEF-54: a webhook fires with the correct payload on a new vulnerable asset (none on the baseline scan). DEF-47: valid PDF (real metrics) and DOCX (opens, contains the data), 401 without a session.